

Deterrence Without Standards

The Case for Mandatory Physical Security Requirements in the Oil and Natural Gas Sector

DBA-GAS-POL — Policy Companion

Issued Under: DBA-GAS Sector Framework

Version 1.2

April 2026

Timothy E. Roxey

Eclectic Technologies

Prepared for: ONG Sector Trade Associations, Congressional Staff, TSA, and FERC

Preface

The North American Electric Reliability Corporation's Critical Infrastructure Protection standard CIP-014 — mandatory physical security requirements for high-impact electric transmission substations — did not emerge from a regulatory agency's initiative. It emerged from an industry that had watched a sophisticated physical attack nearly cause a cascading grid failure, concluded that voluntary guidelines were insufficient against that threat, and worked with its regulator to build a mandatory framework it could live with. That process took years of industry engagement, technical working groups, and iterative standard development. The result was imperfect, as all standards are. But it established something that voluntary guidelines cannot: a baseline. Every operator above the threshold knows what is required. Every regulator knows what to inspect. Every adversary knows that the target set is hardened to a defined minimum.

The author participated in the development and implementation of that framework as Vice President and Chief Security Officer at NERC. The experience was instructive not only in what mandatory standards can accomplish, but in what their absence permits. A sector without mandatory physical security standards is a sector in which the adversary can identify the least-hardened facilities and plan accordingly. It is a sector in which the government cannot assess the baseline security posture because there is no baseline. And it is a sector in which deterrence — the strategic objective that security investment is ultimately meant to serve — is structurally impossible to achieve.

The Oil and Natural Gas sector is that sector today. This document makes the case for changing that and for the trade associations representing the sector's owners and operators to lead the change.

1. The Deterrence Problem

1.1 Deterrence Theory Applied to Critical Infrastructure

Deterrence is the condition in which a potential adversary concludes that the costs and risks of an attack outweigh its anticipated benefits. In the nuclear context, where deterrence theory was most fully developed, the mechanism is straightforward: the adversary believes that an attack will result in unacceptable retaliation. In the context of critical infrastructure, the mechanism is different. Still, the logic is the same: the adversary must believe that attacking the infrastructure will not produce the strategic outcome it seeks, either because the infrastructure is hardened against the attack, because the attack will be detected and interdicted, or because the system will recover faster than the adversary's campaign requires.

Three forms of deterrence are relevant to critical infrastructure protection:

Deterrence by punishment. The adversary refrains from attacking because it believes the attack will be attributed and lead to unacceptable consequences — military, economic, or

diplomatic. This form of deterrence requires attribution capability, response authority, and the credibility to act. It is the form most associated with state-level deterrence and is least directly influenced by the physical security posture of individual facilities.

Deterrence by denial. The adversary refrains from attacking because it concludes the attack will not succeed — the target is hardened, defended, or redundant in ways that prevent the adversary from achieving its operational objective. This form of deterrence is directly produced by physical security investment, and it is the form most relevant to the mandatory standards argument. A sector with consistent, mandatory physical security standards presents a hardened target set that denial-based deterrence requires. A sector with voluntary guidelines presents an inconsistent set of targets, allowing the adversary to select the least-hardened facilities.

Deterrence by resilience. The adversary refrains from attacking—or attacks and fails to achieve strategic effect—because the target system recovers faster than the adversary's campaign can sustain. Resilience-based deterrence requires investment in redundancy, recovery architecture, and mutual assistance capability. It is the form of deterrence that the Oil and Natural Gas sector's existing mutual assistance programs and storage infrastructure are designed to support, and it is the form that mandatory physical security standards reinforce by reducing the severity of the initiating event that resilience mechanisms must absorb.

1.2 Why Voluntary Frameworks Cannot Produce Deterrence

Voluntary compliance frameworks are appropriate for managing risks distributed across a large population of facilities with widely varying threat profiles, where the cost of compliance is high, and the probability that any individual facility will be targeted is low. They are not appropriate for managing risks at the design basis threat tier — deliberate, sophisticated, state-directed military action targeting the highest-consequence facilities in the most consequential sector.

The fundamental problem is visibility. Deterrence by denial requires that the adversary believe the target is hardened. That belief requires evidence — observable, consistent, verifiable evidence that the sector has invested in physical security to a defined standard. Voluntary guidelines produce none of this evidence. An adversary planning against the Oil and Natural Gas sector cannot determine, from open sources or from intelligence collection, which facilities have implemented voluntary guidelines and which have not. But it can determine — with high confidence — that implementation is inconsistent, that there is no enforcement mechanism, and that the least-hardened facilities in the sector are available targets.

Voluntary frameworks also fail the government. A regulator that cannot inspect for compliance with voluntary guidelines cannot assess the sector's security baseline. It cannot identify the facilities most in need of investment. It cannot provide Congress or the executive branch with an accurate picture of the sector's security posture. And it cannot tell allied governments — whose energy security depends on U.S. export infrastructure — whether that infrastructure meets any defined standard. In the post-Nord Stream environment, the inability to assure allied partners of

the security baseline at U.S. LNG export terminals is both a foreign-policy liability and a national-security one.

1.3 The Incoherence of the Current Posture

The current U.S. critical infrastructure protection framework is deterrence-incoherent across sectors. The electricity subsector operates under mandatory physical security standards — NERC CIP-014 — that require asset owners above defined thresholds to conduct threat assessments, develop physical security plans, and submit those plans to third-party verification. The Oil and Natural Gas sector operates under voluntary guidelines that require nothing. These two sectors are not independent: natural gas fuels forty percent of U.S. electricity generation, and the interdependency runs in both directions. An adversary that understands this interdependency will not attack the hardened sector when the unhardened sector provides an equivalent or superior pathway to the same strategic objective.

The adversary does not organize its targeting by regulatory jurisdiction. The regulatory framework does. That asymmetry is not merely an administrative inconvenience — it is a strategic vulnerability that sophisticated adversaries are positioned to exploit. Closing it requires mandatory physical security standards for the Oil and Natural Gas sector that align the sector's hardening posture with the electricity subsector's and present a consistent, verifiable, deterrence-supporting baseline for adversaries, allies, and the public.

2. The Evidentiary Record

2.1 Colonial Pipeline: The Domestic Proof of Concept

In May 2021, a ransomware attack by the DarkSide criminal organization caused Colonial Pipeline — the operator of the largest petroleum product pipeline in the United States, which supplies approximately 45 percent of the fuel consumed on the East Coast — to shut down operations for six days. The attack did not compromise the operational technology systems that control the pipeline; it compromised the IT systems that manage billing and supply chain operations. Colonial's decision to shut down the pipeline was precautionary — management could not confirm the extent of the intrusion and was not willing to operate the OT systems while the IT network was compromised.

The consequences were immediate and significant: fuel shortages across the Southeast and Mid-Atlantic, panic buying, price spikes, and a declaration of regional emergency in multiple states. The federal government activated emergency fuel transportation waivers. The President issued an executive order on improving cybersecurity. And the Transportation Security Administration issued Security Directives — mandatory requirements — for pipeline cybersecurity within weeks of the incident.

The Colonial Pipeline event contains the entire argument for mandatory standards in a single case study. The voluntary framework in place before the incident had not led to consistent implementation of cybersecurity practices across the pipeline sector. The incident revealed the gap. The regulatory response — mandatory Security Directives issued reactively, without the benefit of sustained industry engagement, in the immediate aftermath of a crisis — was exactly the outcome that proactive mandatory standard development is designed to prevent. The industry got mandatory regulation; it did not get the opportunity to shape it under non-crisis conditions. That is the choice that voluntary frameworks ultimately present: proactive mandatory standards developed with industry participation, or reactive mandatory standards imposed after the incident that demonstrates the gap.

Colonial Pipeline was a cybersecurity incident. The physical security gap is larger and less addressed. The TSA Security Directives were issued after Colonial established mandatory cybersecurity requirements for pipeline operators. No equivalent physical security mandate followed. The voluntary Pipeline Security Guidelines remain the sector's sole physical security reference — guidelines that existed before Colonial and before Nord Stream, and that remain unchanged in their voluntary character today.

2.2 Nord Stream I and II: State-Actor Willingness

The September 2022 coordinated destruction of three of the four Nord Stream pipeline strings beneath the Baltic Sea established, beyond reasonable analytical dispute, that state-level actors are willing to execute precision attacks against critical energy infrastructure with strategic intent and deliberate ambiguity in attribution. The attack destroyed approximately 55 billion cubic meters of annual transmission capacity — infrastructure representing a combined capital investment exceeding \$20 billion — in a single, coordinated event timed to coincide with the onset of the European winter heating season.

The Nord Stream attack is the evidentiary anchor for the Design Basis Threat defined in the companion DBA-GAS Sector Framework and DBA-GAS-FC1 Natural Gas Transmission document. For the deterrence argument, its significance is different: it demonstrates that the adversary has already made the strategic calculation that attacking pipeline infrastructure is an acceptable and effective instrument of coercive pressure. The question is not whether a sophisticated adversary would attack U.S. pipeline or LNG terminal infrastructure. The question is what prevents it from doing so. The answer, under the current voluntary framework, is: nothing structural. Attribution risk and the uncertainty of consequence — the elements of deterrence by punishment — are present. Deterrence by denial — the hardened, consistent, verifiable target set that mandatory standards produce — is absent.

2.3 Ukraine: Systematic Targeting as Military Doctrine

The Russian military campaign against Ukrainian energy infrastructure, conducted with increasing intensity through 2022 and 2023, established systematic energy infrastructure

targeting as an operational doctrine rather than an incidental consequence of military operations. Russian forces deliberately and repeatedly struck natural gas compression facilities, underground storage sites, electricity generation assets, and the transmission infrastructure connecting them — in a coordinated campaign designed to degrade civilian heating capacity and industrial production ahead of winter heating seasons.

The Ukraine campaign is relevant to the deterrence argument for two reasons. First, it demonstrates that the threat is not theoretical — an adversary willing to systematically destroy energy infrastructure in one theatre has developed the doctrine, targeting methodology, and operational willingness to do so in others. Second, it demonstrates what the absence of deterrence produces. Ukraine did not deter the energy infrastructure campaign because it could not — it lacked both the military capacity to impose costs on the attacker and the hardened, redundant infrastructure needed to deny the attacker the strategic effect it sought. The result was a civilian population managing life-threatening heating fuel shortages while simultaneously defending against military aggression.

The United States is not Ukraine. It has a significantly greater capacity for deterrence by punishment. But deterrence by denial — the hardened infrastructure that forces the adversary to conclude the attack will not produce the strategic effect it seeks — requires mandatory standards, consistent implementation, and verifiable compliance. The voluntary framework does not produce it.

3. The Regulatory Asymmetry

3.1 CIP-014: What Mandatory Standards Accomplish

NERC CIP-014 — Physical Security — was approved by FERC in 2014 following the April 2013 physical attack on PG&E's Metcalf transmission substation in California, in which attackers used high-powered rifles to destroy seventeen transformers, causing approximately fifteen million dollars in damage and nearly triggering a cascading grid failure in Silicon Valley. The standard requires transmission owners and operators that meet defined risk thresholds to:

- ☐ Conduct a risk assessment to identify transmission stations and substations that, if rendered inoperable or damaged, could result in widespread instability, uncontrolled separation, or cascading failures.
- ☐ Have an unaffiliated third party verify the risk assessment methodology and the identification of high-impact facilities.
- ☐ Conduct a physical security assessment of each identified facility.
- ☐ Develop and implement a physical security plan for each identified facility that addresses threats and vulnerabilities identified in the assessment.
- ☐ Have an unaffiliated third party review the physical security plan.

- Conduct exercises to test the physical security plan.

CIP-014 is not perfect. Its threshold determinations have been criticized as leaving some consequential facilities below the mandatory coverage line. Its third-party verification requirements add cost and administrative burden. But it accomplishes the fundamental objective that voluntary guidelines cannot: it establishes a baseline. Every transmission owner above the threshold knows what is required. FERC can inspect for compliance. NERC can assess the sector's aggregate security posture. And the adversary faces a consistently hardened target set rather than an inconsistent one.

3.2 TSA Pipeline Security Guidelines: What Voluntary Frameworks Cannot Accomplish

TSA's Pipeline Security Guidelines, most recently updated in 2018, provide recommended practices for the physical security of natural gas and liquid petroleum pipelines. They address facility characterization, criticality assessment, risk analysis, security measures, and response planning. They are comprehensive, technically sound, and widely distributed. They are also entirely voluntary.

No pipeline operator is required to implement any element of the Pipeline Security Guidelines. TSA has no inspection authority for physical security compliance — it can conduct voluntary assessments at operator invitation, but it cannot compel access or cite violations. There is no penalty for non-implementation. There is no mechanism for TSA or any other federal agency to assess the sector's aggregate physical security posture against the guidelines' recommendations. There is no third-party verification requirement. And there is no public or classified reporting on implementation rates that would allow Congress, the executive branch, or allied governments to assess whether the sector's physical security posture is adequate against the design basis threat.

The gap between CIP-014 and the Pipeline Security Guidelines is not a gap between two different approaches to the same problem. There is a gap between a framework designed to produce deterrence and a framework that cannot.

3.3 The Side-by-Side: A Structural Comparison

The following table compares the mandatory CIP-014 framework for the electricity subsector with the voluntary Pipeline Security Guidelines framework for the Oil and Natural Gas sector across the dimensions that determine whether a security framework can support deterrence. The full detailed comparison is provided in Appendix A.

Dimension	CIP-014 (Electricity)	TSA Guidelines (ONG)
Legal character	Mandatory — FERC-approved NERC Reliability Standard	Voluntary — recommended practices only
Applicability threshold	Risk-based; defined criteria for high-impact facilities	Self-selected; operators determine applicability

Dimension	CIP-014 (Electricity)	TSA Guidelines (ONG)
Risk assessment	Required; methodology subject to third-party verification	Recommended; no verification requirement
Physical security plan	Required for each identified facility	Recommended; no requirement to develop or maintain
Third-party review	Required for both assessment and plan	Not required
Implementation deadline	Defined compliance timeline with regulatory oversight	No deadline; no compliance requirement
Government inspection	NERC audit authority; FERC oversight	TSA voluntary assessments are by invitation only
Enforcement	Civil penalties up to \$1M per violation per day	No penalty authority for physical security
Incident reporting	Mandatory reporting to E-ISAC and the government	Voluntary reporting encouraged
Sector baseline visibility	Aggregate compliance data available to NERC and FERC	No aggregate visibility; implementation unknown
Deterrence signal	Consistent, verifiable hardening across covered facilities	Inconsistent; adversary cannot assess implementation
Allied assurance	FERC can certify compliance posture to allied governments	No assurance mechanism available

4. Why Voluntary Frameworks Fail Against the Design Basis Threat

4.1 Inconsistent Implementation

Voluntary frameworks produce heterogeneous implementation across the asset population. Some operators — typically the largest, best-resourced, and most security-conscious — implement voluntary guidelines comprehensively. Others implement selectively. Others do not implement at all. The distribution of implementation across the sector is unknown to the government and the sector itself because voluntary frameworks include no reporting requirements to enable an aggregate assessment.

A sophisticated adversary with intelligence-collection capabilities can identify the implementation distribution. It can distinguish between operators that have invested in perimeter security, surveillance, and access control from those that have not. Targeting logic for a Tier 1 adversary planning a coordinated attack will naturally select the least-hardened facilities in the most consequential locations. Voluntary frameworks, by producing inconsistent implementation, provide the adversary with exactly this targeting opportunity.

Mandatory standards eliminate the opportunity to target by establishing a floor. Every operator above the coverage threshold meets a defined minimum. The adversary cannot reliably identify

the least-hardened facility in the covered set because the framework prevents the most extreme implementation gaps from existing. This is the core deterrence-by-denial mechanism that mandatory standards produce and voluntary frameworks cannot.

4.2 No Enforcement Mechanism

Voluntary frameworks have no consequence for non-implementation. An operator that reads the Pipeline Security Guidelines and declines to implement any of their recommendations faces no regulatory penalty, no inspection, no public disclosure, and no competitive disadvantage. The framework provides no incentive for compliance beyond the operator's own risk assessment and security culture.

The absence of enforcement also eliminates the feedback loop that makes standards improve over time. NERC CIP standards improve through the violation and penalty process — when operators receive penalties for non-compliance, the industry engages with the standards body to clarify requirements, identify implementation challenges, and update standards to reflect operational realities. Voluntary frameworks have no equivalent feedback mechanism. The guidelines are issued; some operators implement them; no one knows how many; the guidelines are updated on a periodic schedule disconnected from implementation experience.

4.3 No Baseline Visibility

The federal government currently has no reliable assessment of the physical security posture of the Oil and Natural Gas sector's critical facilities. TSA's voluntary assessment program has conducted several hundred assessments over its history — a small fraction of the sector's asset population — at operators' invitation, with no requirement to act on findings. The aggregate data from these assessments does not constitute a sector baseline; it constitutes a self-selected sample of operators willing to be assessed, which is almost certainly biased toward the more security-conscious end of the implementation distribution.

This visibility gap has direct consequences for policy. Congress cannot appropriate resources to address a security gap it cannot measure. The executive branch cannot prioritize investment or diplomatic assurance without baseline data. And the intelligence community cannot assess the sector's resilience against a known threat without knowing what security investments have been made at the facilities most likely to be targeted. The Colonial Pipeline incident exposed this visibility gap in cybersecurity. In the immediate aftermath, neither TSA nor CISA could rapidly assess the sector's cybersecurity posture because there was no mandatory reporting or compliance framework from which to derive that assessment. The physical security gap is larger.

4.4 No Deterrence Signal

Deterrence by denial requires that the adversary receive a credible signal that the target set is hardened. Voluntary frameworks cannot produce this signal because they cannot guarantee that

the hardening has occurred. A government that cannot verify its sector's security posture cannot credibly assure adversaries that an attack on the sector will not succeed. The signal that voluntary frameworks send is the opposite of deterrence: they signal that security investment is uneven, that the least-hardened facilities exist and can be identified, and that the regulatory framework will not prevent the attack.

This is not a hypothetical concern. The Nord Stream attack was executed against infrastructure whose physical security posture — subsea pipelines without active surveillance or hardening against underwater explosive attack — was known to the adversary. The attack succeeded because the adversary correctly assessed that the target was undefended against the chosen modality. Mandatory standards that required active subsea surveillance and physical protection of critical pipeline segments would have either prevented the attack or required the adversary to invest in more sophisticated attack capabilities — the definitional outcome of deterrence by denial.

5. The Legislative Path

5.1 Existing Authority and Its Limits

TSA has statutory authority to issue mandatory security directives for surface transportation, including pipelines, under 49 U.S.C. § 114. This authority was exercised in the cybersecurity context after Colonial Pipeline — TSA issued Security Directives SD-02C and SD-01D establishing mandatory cybersecurity requirements for pipeline operators. The same authority could theoretically be used to issue mandatory physical security directives.

The practical limits of this authority are significant. Security Directives are emergency instruments — they are issued without the notice-and-comment rulemaking process that produces durable, industry-engaged standards. They are difficult to enforce against a large, geographically dispersed operator population. And they do not create the NERC CIP model's self-regulatory structure, in which the industry body (NERC) develops and enforces standards under FERC oversight — a model that maintains industry engagement and technical expertise in the standard development process.

FERC has authority over interstate natural gas pipelines under the Natural Gas Act and over LNG import/export terminals. FERC's security authority is limited — it is primarily a reliability and economic regulator rather than a security regulator. Expanding FERC's explicit security authority, or directing FERC to coordinate with TSA on mandatory physical security standards for the facilities under its jurisdiction, is a legislative option that would leverage FERC's existing relationship with the industry.

5.2 The Legislative Vehicle

Three legislative vehicles are available for mandatory O&G physical security standards:

Standalone legislation. A Pipeline Physical Security Act modeled on the structure of the Energy Policy Act of 2005's grid reliability provisions, which authorized FERC to approve NERC reliability standards as mandatory and enforceable. A parallel structure would authorize TSA — or a designated industry organization operating under TSA oversight — to develop mandatory physical security standards for pipeline facilities above defined risk thresholds, with FERC approval authority for the standards applicable to facilities under FERC's existing jurisdiction.

DHS authorization or reauthorization. The periodic DHS authorization process provides a vehicle to expand TSA's physical security standard authority from emergency directive authority to full notice-and-comment rulemaking authority for critical pipeline facilities. This vehicle is lower-profile than standalone legislation and may be more achievable in a constrained legislative environment.

National Defense Authorization Act. The NDAA has historically been the vehicle for critical infrastructure security provisions that have national security implications. The deterrence argument — mandatory standards as a component of the national defense posture — positions mandatory O&G physical security standards as a defense bill provision rather than a regulatory bill provision, thereby changing the political dynamics and committee jurisdiction.

Of the three vehicles, the NDAA pathway is strategically superior for this argument. Framing mandatory O&G physical security standards as a national defense measure — necessary to support deterrence against state-level adversaries and to assure NATO allies of the reliability of U.S. energy supply — aligns with the NDAA's mandate. It avoids the anti-regulatory political environment surrounding standalone regulatory legislation.

5.3 The Regulatory Model: CIP-014 Adapted for O&G

The CIP-014 model, adapted to the characteristics of the Oil and Natural Gas sector, serves as the template for mandatory standards. The key adaptations required are:

Asset classification threshold. CIP-014 uses bulk electric system impact criteria to identify covered facilities. An O&G equivalent would use consequence-based criteria: facilities whose loss or significant damage would result in defined curtailment volumes of supply, cross-sector cascade effects, or impacts on national defense supply. Compressor stations on high-consequence interstate pipeline corridors, major refinery facilities, and LNG export terminals would be candidates for the highest-tier coverage.

Self-regulatory structure. The NERC model — in which an industry organization develops standards, FERC approves and enforces them — preserves technical expertise in the standard development process and maintains industry engagement. An O&G equivalent could be structured through an existing sector organization (API, AGA, or the ONG SCC) operating under TSA and FERC oversight, with the same third-party verification and penalty structure as CIP-014.

Graduated requirements. Not all O&G facilities present the same consequence profile. A graduated framework — tiered requirements based on asset criticality, similar to the DHS tiered approach under CFATS — allows mandatory standards to concentrate the most rigorous requirements on the highest-consequence facilities while establishing baseline requirements across the broader covered population.

Enforcement structure. Civil penalty authority for physical security non-compliance, equivalent to FERC's penalty authority under the Federal Power Act. Without a credible enforcement mechanism, mandatory standards become de facto voluntary — operators that assess their penalty risk as low will treat requirements as optional. The penalty structure does not need to be punitive; it needs to be credible.

6. The Trade Association Imperative

6.1 The Counterintuitive Ask

Trade associations representing asset owners and operators in regulated industries typically oppose mandatory standards. The business case for opposition is straightforward: mandatory standards impose compliance costs, constrain operational flexibility, and create liability exposure. The historical posture of O&G trade associations on security regulation has followed this pattern — supporting voluntary frameworks, opposing mandatory requirements, and emphasizing the sector's existing security investments as evidence that mandatory standards are unnecessary.

This document asks the trade associations — AGA, API, the ONG SCC, and their member organizations — to take the opposite position. Not because mandatory standards are costless, or because the trade association's opposition to regulatory burden is wrong in the general case. But because the alternative to trade-association-led mandatory standards is not the status quo. The alternative is reactive mandatory standards imposed without industry participation in the aftermath of an incident that demonstrates the gap.

Colonial Pipeline is the proof. The TSA cybersecurity Security Directives that followed were developed rapidly, under crisis conditions, without the sustained industry engagement that produces workable standards. The industry's preferred outcome — well-designed standards that reflect operational realities and preserve reasonable flexibility — requires industry leadership in standard development. That leadership is available only if the industry engages before the crisis, not after it.

6.2 The Strategic Interest Argument

Beyond the process argument, there is a strategic interest argument for trade association support of mandatory standards that is worth making directly.

Market differentiation. Operators that have invested in physical security cannot differentiate that investment within a voluntary framework because there is no verified baseline against which to measure it. Mandatory standards create a verified baseline — operators above the threshold are demonstrably compliant; operators who exceed it can demonstrate this to customers, counterparties, and insurers. The security investment that the most conscientious operators have already made acquires market value it currently lacks.

Insurance and liability. The insurance market for critical infrastructure is moving toward security posture as an underwriting criterion. Operators that demonstrate compliance with mandatory standards present a more favorable risk profile than operators in a voluntary framework, where implementation cannot be verified. Mandatory standards, by creating verifiable compliance, may reduce insurance costs for compliant operators over time — a direct financial benefit that partially offsets compliance costs.

Allied market access. U.S. LNG exporters compete in a global market where European buyers — now dependent on U.S. supply due to the Nord Stream pipeline outage — are increasingly attentive to supply security. A U.S. LNG export terminal that can demonstrate compliance with mandatory physical security standards offers a more credible supply security guarantee to European buyers than one operating under voluntary guidelines. In a market where supply reliability is a premium attribute, mandatory standards create commercial advantage.

Regulatory certainty. The single largest cost in regulatory compliance is uncertainty — operators who do not know what will be required make suboptimal investment decisions, over-investing in some areas and under-investing in others. Mandatory standards, once established, provide the regulatory certainty that allows operators to make durable security investments with confidence that the regulatory landscape will not shift under them.

6.3 The Historical Precedent

The electricity industry's engagement with the NERC CIP process — including CIP-014 — provides the most directly applicable precedent. The industry did not enthusiastically embrace mandatory cybersecurity and physical security standards. It engaged, negotiated, challenged, and worked within the process to shape standards that were achievable and operationally sound. The result was a mandatory framework that the industry has lived with, improved, and increasingly treats as a baseline rather than a burden.

The chemical industry's engagement with CFATS — the Chemical Facility Anti-Terrorism Standards — provides a second precedent. The American Chemistry Council and its member companies engaged with DHS in developing CFATS to ensure that the tiered framework reflected actual risk levels and that compliance timelines were achievable. The outcome was a mandatory framework that the industry helped design and can implement.

In both cases, the industry's engagement in the standard development process produced better standards than would have emerged from a purely regulatory process. That outcome — standards

designed with industry expertise rather than imposed on the industry — is available to the Oil and Natural Gas sector if the trade associations choose to lead rather than oppose.

6.4 The Direct Ask

The ask to AGA, API, the ONG SCC, and member trade associations is specific:

- Publicly support the development of mandatory physical security standards for high-consequence Oil and Natural Gas facilities, framed as a national security imperative and modeled on the CIP-014 structure.
- Engage with TSA, FERC, and relevant congressional committees to shape the legislative vehicle and standard development process before crisis conditions remove the opportunity for constructive engagement.
- Establish a working group — through the ONG SCC or an equivalent body — to develop the technical content of proposed mandatory standards, drawing on the sector's operational expertise and the lessons of the CIP-014 development experience.
- Communicate to member companies that proactive engagement in mandatory standard development is in their strategic interest, and that the alternative — reactive mandatory regulation following an incident — is the outcome that collective inaction produces.

Kimberly Denbow's testimony before Congress on cybersecurity incident reporting demonstrated that the sector has credible voices capable of engaging productively with the legislative process on security matters. The argument for the physical security standard needs those voices at the table.

6.5 The Three-Part Offer: Making the Business Case

Trade association support for mandatory physical security standards is not an act of regulatory altruism. It is a business decision that requires a business case. That case rests on three elements that must be part of any mandatory standards framework, and that the trades should insist upon as conditions of their support. Taken together, these three elements transform the compliance calculus from a purely cost-imposing exercise into a rational strategic investment.

6.5.1 *Liability Protection for Compliant Operators*

An operator that implements mandatory physical security standards in good faith, meets all compliance requirements, and still suffers a successful attack should not face the same tort liability as an operator that ignores voluntary guidelines entirely. Compliance with mandatory standards should constitute a meaningful affirmative defense in litigation arising from security incidents at covered facilities.

The legal architecture for this protection exists. The SAFETY Act — the Support Anti-Terrorism by Fostering Effective Technologies Act of 2002 — provides liability limitations for providers of

qualified anti-terrorism technologies and services. CFATS compliance provides a degree of liability protection for chemical facilities operating within the regulatory framework. A mandatory Oil and Natural Gas physical security standard should explicitly incorporate a compliance-based liability protection provision, modeled on these precedents, that gives compliant operators a meaningful legal shield that non-compliant operators do not receive.

This is not a blanket immunity from liability — operators that comply in form but not in substance, or that know of specific vulnerabilities and fail to address them, should not be protected. It is a recognition that an operator who has met a mandatory standard, verified by a third party, has exercised the diligence required by the regulatory framework. That diligence should be rewarded with reduced exposure to litigation after a successful attack by a sophisticated adversary that the operator could not have prevented, regardless of the operator's security investment.

For the trade associations, liability protection is the argument that converts the legal departments of member companies from opponents of mandatory standards to supporters. The current voluntary framework offers no liability protection — an operator that implements every voluntary guideline recommendation faces the same litigation exposure as one that ignores them, because voluntary compliance is not legally cognizable as a standard of care in the same way that mandatory compliance is. Mandatory standards with liability protection give compliant operators something the voluntary framework cannot: a legally defensible position.

6.5.2 Cost Recovery Through Rate Cases

Mandatory security compliance is not free. Physical security investments — perimeter hardening, surveillance systems, access control infrastructure, exercise programs, and third-party verification costs — represent real capital and operating expenditures that initially fall on asset owners and operators. For regulated entities subject to FERC rate jurisdiction — interstate natural gas pipeline operators and LNG terminal owners — the question of who ultimately bears these costs is a rate-making question, not merely a business one.

The electricity sector precedent is instructive. FERC has consistently recognized mandatory CIP compliance costs as prudent and necessary expenditures recoverable through the rate-making process. Capital investments in physical security infrastructure required by CIP-014 are treated as rate base additions; operating costs for compliance programs are treated as allowable operating expenses. The rationale is straightforward: mandatory security requirements imposed by the regulatory framework as a condition of operating the regulated infrastructure should be recoverable costs of providing that regulated service.

The same logic applies to mandatory Oil and Natural Gas physical security standards. Interstate natural gas pipeline operators subject to FERC jurisdiction should be able to recover mandatory physical security compliance costs through their FERC-regulated rates. This requires either a FERC policy statement or a legislative clarification confirming that mandatory physical security

compliance costs are prudent and recoverable — a clarification that FERC should be willing to provide, because it aligns the rate-making incentive with the security objective.

For the trade associations, cost recovery is the argument that converts the finance departments of member companies from opponents to neutral or supportive. An investment that is recoverable through regulated rates is categorically different from an investment that reduces shareholder returns. Rate recovery does not eliminate compliance costs — ratepayers bear them — but it allocates that cost appropriately to the public that benefits from hardened infrastructure, rather than concentrating it on shareholders who have no greater ability to prevent sophisticated military attacks than ratepayers do.

6.5.3 Collaborative Standard Development

The most important of the three elements is the one that addresses the process, not the outcome. Trade associations do not oppose mandatory standards because they oppose security. They oppose mandatory standards because they do not trust that the resulting requirements will be technically sound, operationally achievable, or competitively equitable. That distrust is not unreasonable — it is grounded in experience with regulatory processes that produced requirements written without adequate operational input.

Colonial Pipeline is the cautionary example. The TSA cybersecurity Security Directives issued after the incident were developed under crisis conditions, without sustained industry engagement, and produced requirements that the industry found operationally challenging in ways that a deliberate standard development process would have identified and addressed. The industry got mandatory regulation; it did not get the opportunity to shape it. That outcome — not mandatory standards per se — is what the trade associations should be trying to prevent.

The NERC CIP process provides the alternative model. NERC standards are developed by industry volunteers — engineers, security professionals, and operational experts from utilities across North America — working through a structured drafting and comment process before FERC approval. The result is standards that reflect operational realities, that have been stress-tested by the people who will implement them, and that evolve through a continuous improvement process informed by implementation experience. The industry shaped the standards it operates under, and the standards are better for it.

The mandatory Oil and Natural Gas physical security standard framework should replicate this model. The legislative vehicle should authorize and require a collaborative development process — not a TSA-drafts-and-industry-comments process, but a genuine industry-leads-and-regulator-approves process modeled on the NERC/FERC structure. AGA, API, and the ONG SCC should be at the drafting table, not the comment table. The technical content of the standards should emerge from the sector's operational expertise and be validated by the regulatory authorities, TSA, and FERC.

For trade associations, collaborative development is the guarantee that turns mandatory standards from a threat into an opportunity. Standards that the industry helped write are standards the industry can live with, implement effectively, and improve over time. Standards imposed without industry participation are standards the industry will spend years challenging and seeking relief from. The choice is available only before the crisis. Afterward, the collaborative option closes.

6.6 The Integrated Offer

Liability protection, cost recovery, and collaborative development are not three separate asks. They are a single integrated package that defines the conditions under which trade association support for mandatory standards is strategically rational. Each element addresses a different dimension of the opposition:

- Liability protection addresses the legal department's objection: compliance reduces exposure rather than creating a new liability standard.
- Cost recovery addresses the finance department's objection: mandatory compliance costs are recoverable for regulated entities rather than borne solely by shareholders.
- Collaborative development addresses the policy department's objection: the industry shapes the standards rather than receiving them.

A trade association that secures all three elements has converted a regulatory imposition into a negotiated framework that its members can support, implement, and benefit from. A trade association that opposes mandatory standards without offering this alternative will eventually receive mandatory standards without these protections — because the incident that makes standards unavoidable will remove the opportunity for negotiation at the same time it removes the option of inaction.

7. Implementation Framework

7.1 Asset Identification and Classification

A mandatory O&G physical security standard should begin with consequence-based asset classification, using criteria analogous to CIP-014's bulk electric system impact analysis. Three tiers are proposed:

Tier 1 — Nationally Critical. Facilities whose loss or significant damage would result in supply curtailments affecting multiple states, cross-sector cascade effects (particularly electricity generation impacts), or national defense supply impacts. Major interstate pipeline compressor stations on high-consequence corridors, LNG export terminals, and major petroleum refineries supplying military logistics fuel are candidate Tier 1 assets. Tier 1 assets receive the full CIP-014-equivalent treatment: a mandatory threat assessment, a third-party-verified physical security plan, mandatory exercises, and FERC/TSA oversight.

Tier 2 — Regionally Critical. Facilities whose loss would produce significant regional supply disruptions, affecting a single state or metropolitan area, or producing supply impacts on critical sectors within a defined region. Intrastate pipeline compressor stations, underground storage facilities, and regional refinery facilities are candidate Tier 2 assets. Tier 2 assets are subject to mandatory threat assessment and physical security plan requirements, with third-party review on a longer cycle than Tier 1.

Tier 3 — Baseline Coverage. Facilities that meet defined size or throughput thresholds but do not rise to Tier 1 or 2 consequence levels. Tier 3 assets receive baseline mandatory requirements — perimeter security standards, access control requirements, and incident reporting obligations — without the full planning and verification requirements of higher tiers.

7.2 Threat Assessment Requirements

Each covered facility must conduct a documented threat assessment that addresses the full threat taxonomy of the DBA-MA framework—not only the all-hazards baseline of existing voluntary guidelines. The threat assessment must address:

- ☐ Kinetic attack modalities: explosive demolition, standoff rifle or rocket attack, and vehicle-borne explosive device.
- ☐ Cyber-kinetic combined arms: ICS/SCADA compromise as a precursor or complement to physical attack.
- ☐ UAS modalities: aerial, maritime surface, and subsea unmanned systems, as applicable to the facility's geographic and operational context.
- ☐ Insider threat: deliberate sabotage by employees, contractors, or vendor personnel with facility access.
- ☐ Supply chain threat: pre-attack interdiction of critical equipment or spare parts supplies.

The threat assessment methodology for Tier 1 assets must be subject to third-party verification to confirm that the assessment addresses the required threat categories and that the asset identification methodology is sound.

7.3 Physical Security Plan Requirements

Each covered facility must develop and maintain a physical security plan addressing vulnerabilities identified in the threat assessment. Plan elements must include at a minimum:

- ☐ Perimeter security: defined standards for perimeter barriers, access control, intrusion detection, and lighting, calibrated to the facility's threat tier.
- ☐ Surveillance: continuous monitoring capability sufficient to detect unauthorized approach within defined warning times for each relevant threat modality.

- Communications: protected communications to law enforcement, company security operations, and government notification points, with defined notification timelines for security incidents.
- Response coordination: pre-established relationships with Local Law Enforcement Agencies (LLEAs), USCG (for maritime facilities), and federal security agencies, with documented response protocols and periodic joint exercises.
- Recovery: defined procedures for rapid restoration of security posture following an incident, including equipment replacement priorities and mutual assistance activation.

Physical security plans for Tier 1 assets must be reviewed by an unaffiliated third party and submitted to TSA. Plans must be updated following significant facility modifications, significant changes to the threat environment, or security incidents that reveal deficiencies in the plan.

7.4 Verification and Enforcement

Third-party verification. Qualified unaffiliated third parties must review Tier 1 and Tier 2 asset threat assessments and physical security plans. Qualifications for third-party reviewers should be defined by TSA in consultation with the industry working group, drawing on the standards for CFATS third-party reviewers and for NERC CIP compliance assessors.

Government inspection. TSA should have inspection authority for physical security compliance at covered facilities, including the authority to require the production of threat assessments, physical security plans, and verification reports. Inspection should be risk-based, focusing on Tier 1 facilities and those with identified compliance deficiencies.

Penalty structure. Civil penalties for non-compliance should be calibrated to the facility's tier and the severity of the deficiency. Maximum penalties should be sufficient to create a credible deterrent to enforcement — the FERC penalty structure under the Federal Power Act (up to \$1 million per violation per day) provides the reference point. A graduated penalty structure, with lower penalties for good-faith compliance efforts and higher penalties for willful non-compliance, preserves the incentive for early engagement without creating excessive liability for operators working in good faith toward compliance.

Mandatory incident reporting. Physical security incidents at covered facilities — successful attacks, attempted attacks, and significant security system failures — must be reported to TSA and the ONE-ISAC (formerly ONG-ISAC) within defined timelines. Reporting requirements should protect sensitive information from public disclosure while ensuring that government and sector partners are promptly aware of incidents that may indicate coordinated threat activity.

8. Conclusions and Call to Action

8.1 The Core Argument

The Oil and Natural Gas sector's current physical security framework cannot provide deterrence against the design-basis threat. Voluntary compliance guidelines produce inconsistent implementation, provide no baseline visibility to government or industry, send no deterrent signal to adversaries, and cannot assure allied governments of the security of U.S. energy supply infrastructure. The evidentiary record — Colonial Pipeline, Nord Stream, Ukraine — demonstrates that the threat is real, that the adversary is willing, and that the voluntary framework's inadequacy is not theoretical.

Mandatory physical security standards, modeled on CIP-014 and adapted to the O&G sector's characteristics, would close this gap. They would produce a consistent, verifiable, deterrence-supporting baseline. They would give the government the visibility it needs to assess the sector's security posture and target investment. They would assure allied governments of the security of the U.S. energy supply infrastructure. And they would give the sector's most security-conscious operators the market recognition that their investments currently lack.

The choice is not between mandatory standards and the status quo. The choice is between mandatory standards developed proactively with industry participation and those imposed reactively after an incident demonstrating the voluntary framework's failure. Colonial Pipeline made that choice visible in the context of cybersecurity. The physical security equivalent has not yet occurred. The window for proactive engagement is open. It will not remain open indefinitely.

8.2 Call to Action by Audience

To the trade associations — AGA, API, ONG SCC, and member organizations: Lead. Establish the industry working group. Engage with TSA and FERC before the crisis. Shape the standards governing your members' facilities under conditions that allow for deliberate, expert engagement. The alternative is regulation by emergency directive, written under crisis conditions, without your participation.

To congressional staff: The NDAA is the right vehicle. The deterrence argument is the right frame. The CIP-014 model is the right template. The ask is an authorization for mandatory O&G physical security standards, with TSA rulemaking authority, FERC approval for standards applicable to FERC-jurisdictional facilities, and a self-regulatory development process modeled on NERC CIP. This is achievable, defensible, and overdue.

To TSA and FERC: Begin the engagement. Convene the industry working group. Signal that the agencies are prepared to support mandatory standards developed with industry participation, and that the alternative — reactive security directives following an incident — is the outcome that agency inaction produces as surely as industry inaction. The authority exists. The model exists. The threat exists. The remaining variable is the decision to act.

Appendix A: CIP-014 vs. TSA Pipeline Security Guidelines — Detailed Comparison

The following table provides a detailed element-by-element comparison of the mandatory CIP-014 framework for the electricity subsector and the voluntary TSA Pipeline Security Guidelines for the Oil and Natural Gas sector.

Requirement Element	CIP-014	TSA Pipeline Guidelines	Gap Analysis
Mandatory applicability	Yes — FERC-approved, enforceable	No — voluntary adoption	No floor; inconsistent implementation; no deterrence baseline
Risk-based asset identification	Required; defined methodology	Recommended; self-selected	An adversary can identify the least-hardened facilities
Third-party assessment verification	Required for Tier 1	Not required	No independent validation of threat assessment quality
Physical security plan	Required; documented; maintained	Recommended; no documentation requirement	Plans may not exist; no consistency across operators
Third-party plan review	Required	Not required	No independent review; plans may be inadequate
Implementation timeline	Defined; regulatory oversight	None	Indefinite deferral; no compliance date
Government inspection	NERC audit; FERC oversight	Voluntary TSA assessment, invitation-only	The government cannot assess the sector posture
Civil penalty authority	Up to \$1M/violation/day (FERC)	None for physical security	No enforcement credibility; deterrence signal absent
Mandatory incident reporting	Required to E-ISAC and the government	Voluntary reporting encouraged	No sector-wide incident visibility for the government
Exercise requirements	Required; documented	Recommended; no requirement	Plans untested; response capability unknown
Supply chain security	Addressed in related CIP standards	Referenced; no requirement	Equipment procurement security is unaddressed
Third-party access control	Required: personnel risk assessment	Recommended	Contractor and vendor access are inconsistently managed
Aggregate sector baseline	Available to NERC and FERC	Unavailable; no reporting mechanism	Policy, investment, and assurance decisions are made blindly

Appendix B: LNG Terminal Physical Security Standards Gap

LNG terminal physical security occupies a distinct regulatory position from land-based pipeline infrastructure. The Maritime Transportation Security Act (MTSA) and USCG regulations under 33 CFR Part 127 provide a mandatory framework for maritime facility security that is stronger than the voluntary pipeline guidelines — facility security plans are required, the USCG has inspection authority, and enforcement mechanisms are in place. In this respect, the LNG terminal regulatory framework is closer to the CIP-014 model than the Pipeline Security Guidelines framework.

However, three significant gaps remain in the LNG terminal security framework as documented in the companion DBA-MA Use Case: LNG Terminal document:

USV and UUV threat gap. Current MTSA-based facility security plans and USCG security zones were designed for conventional vessel and swimmer threats. Uncrewed surface vehicle (USV) and uncrewed underwater vehicle (UUV) threats — demonstrated by the Houthi maritime campaign and the Nord Stream attack — are not systematically addressed in current terminal security plan requirements. USCG should develop and promulgate specific USV/UUV threat assessment and countermeasure requirements for LNG facility security plans, incorporated as a mandatory element of the MTSA framework.

Aerial UAS gap. FAA airspace regulation and facility security perimeter controls are not integrated into a coherent counter-UAS framework for LNG terminal protection. The authority gap — who can legally take action against an aerial UAS in terminal airspace — is addressed in Appendix C. The facility security plan gap — what detection and response measures are required — should be addressed through USCG facility security plan requirements for aerial UAS threat assessment and countermeasure planning.

FSRU security standards gap. The floating storage and regasification units deployed rapidly across European member states after 2022 were classified and regulated as vessels rather than as fixed critical infrastructure. The security standards applicable to FSRUs — primarily maritime classification society rules and flag state regulations — were not designed for facilities that now occupy the critical infrastructure role that post-2022 FSRUs perform. A coordinated security standards program for FSRU facilities, developed jointly by EU energy security bodies, member state coast guards, and maritime classification societies, would address this gap at the allied level.

The legislative vehicle for LNG terminal USV/UUV and aerial UAS requirements should be the Coast Guard Authorization Act, which provides the vehicle for USCG regulatory authority expansion, in coordination with the broader mandatory O&G physical security standards legislation recommended in the main body of this document.

Appendix C: USCG/FAA Counter-UAS Authority Gap

Counter-UAS authority at energy infrastructure sites is fragmented across multiple federal agencies, creating response gaps. The current authority landscape:

DOD and DHS. The National Defense Authorization Act of 2017 and subsequent amendments granted DOD and DHS limited authority to detect, identify, monitor, and, in defined circumstances, interdict UAS that pose a threat to covered facilities. DHS authority covers certain defined categories of critical infrastructure. Energy infrastructure is not uniformly included in DHS's counter-UAS authority.

FAA. FAA regulates all aircraft, including UAS, operating in U.S. airspace. FAA generally prohibits counter-UAS action — including jamming, spoofing, or physical interdiction — by non-federal entities. Private facility operators have no legal authority to take action against an aerial UAS detected in their airspace, even if the UAS presents a credible threat to the facility.

USCG. USCG has the authority to establish maritime security zones around waterfront facilities, which provides a basis for responding to USV threats within those zones. USCG does not have specific counter-UAS authority for aerial threats to maritime facilities.

The result of this fragmented authority is a detection-to-response gap: a facility operator that detects an aerial UAS approaching a critical facility cannot legally interdict it, and the federal agencies with interdiction authority may lack the assets or situational awareness to respond within the available time window.

The legislative remedy has two components:

Expanded DHS counter-UAS authority. Legislation explicitly including Tier 1 and Tier 2 Oil and Natural Gas facilities within DHS's counter-UAS authority, and authorizing CISA to coordinate counter-UAS response for energy infrastructure in the same manner as it coordinates cybersecurity response. The FAA Reauthorization Act's approach to airport counter-UAS authority provides a legislative template.

Facility operator detection authority. Legislation authorizing operators of covered Tier 1 and Tier 2 facilities to detect, identify, and monitor UAS in defined airspace and maritime zones around their facilities, and to notify federal authorities in real time for interdiction response. This falls short of granting private operators interdiction authority — which raises significant safety and liability concerns — but closes the detection-to-notification gap that currently prevents effective federal response.

Appendix D: Acronyms

AGA	American Gas Association
API	American Petroleum Institute
CFATS	Chemical Facility Anti-Terrorism Standards
CISA	Cybersecurity and Infrastructure Security Agency
CIP-014	Critical Infrastructure Protection Standard 014 — Physical Security (NERC)
DBA-MA	Design Basis Accident — Military Action

DHS	U.S. Department of Homeland Security
DOD	U.S. Department of Defense
E-ISAC	Electricity Information Sharing and Analysis Center
FAA	Federal Aviation Administration
FERC	Federal Energy Regulatory Commission
FSRU	Floating Storage and Regasification Unit
ICS	Industrial Control System
LLEA	Local Law Enforcement Agency
LNG	Liquefied Natural Gas
MTSA	Maritime Transportation Security Act
NDAA	National Defense Authorization Act
NERC	North American Electric Reliability Corporation
ONG SCC	Oil and Natural Gas Subsector Coordinating Council
ONE-ISAC	Oil and Natural Gas Information Sharing and Analysis Center
PHMSA	Pipeline and Hazardous Materials Safety Administration
SCADA	Supervisory Control and Data Acquisition
TSA	Transportation Security Administration
UAS	Unmanned Aerial/Aquatic System (collective)
USCG	United States Coast Guard
USV	Uncrewed Surface Vehicle
UUV	Uncrewed Underwater Vehicle

Revision History

Version	Date	Author	Description
1.0	April 2026	Tim Roxey	Initial draft. Deterrence-theory framework for mandatory physical security standards in the Oil and Natural Gas sector. Issued under DBA-MA Oil and Natural Gas Child Document.
1.1	April 2026	Tim Roxey	Minor revision. Issued as FINAL.
1.2	April 2026	Tim Roxey	Repositioned as DBA-GAS-POL under the DBA-GAS Sector Framework. Cover scope line updated to DBA-GAS-POL designation. Lineage updated from DBA-MA Oil and Natural Gas Child Document to DBA-GAS Sector Framework. Nord Stream body reference updated. ONG-ISAC updated to ONE-ISAC throughout. Revision history table added. File renamed DBA-GAS-POL_Deterrence.

— **END OF DOCUMENT** —